

Red team

4_May

Vulnerability Assessment

A Vulnerability Assessment aims to identify and categorize risks for security weaknesses related to assets within an environment. It is important to note that there is little to no manual exploitation during a vulnerability assessment. A vulnerability assessment also provides remediation steps to fix the issues.

The purpose of a Vulnerability Assessment is to understand, identify, and categorize the risk for the more apparent issues present in an environment without actually exploiting them to gain further access. Depending on the scope of the assessment, some customers may ask us to validate as many vulnerabilities as possible by performing minimally invasive exploitation to confirm the scanner findings and rule out false positives. Other customers will ask for a report of all findings identified by the scanner. As with any assessment, it is essential to clarify the scope and intent of the vulnerability assessment before starting. Vulnerability management is vital to help organizations identify the weak points in their assets, understand the risk level, and calculate and prioritize remediation efforts.

It is also important to note that organizations should always test substantial patches before pushing them out into their environment to prevent disruptions.

Methodology

Below is a sample vulnerability assessment methodology that most organizations could follow and find success with. Methodologies may vary slightly from organization to organization, but this chart covers the main steps, from identifying assets to creating a remediation plan.

8 Steps to Perform a Network Vulnerability Assessment: 1. Conduct risk identification and analysis. 2. Develop scanning policies. 3. Identify scan types. 4. Configure the scan. 5. Perform the scan. 6. Evaluate risks. 7. Interpret results. 8. Create a remediation plan.

Adapted from the original graphic found [here](#).

Understanding Key Terms

Before we go any further, let's identify some key terms that any IT or Infosec professional should understand and be able to explain clearly.

Vulnerability

A Vulnerability is a weakness or bug in an organization's environment, including applications, networks, and infrastructure, that opens up the possibility of threats from external actors. Vulnerabilities can be registered through MITRE's Common Vulnerability Exposure database and receive a Common Vulnerability Scoring System (CVSS) score to determine severity. This scoring system is frequently used as a standard for companies and governments looking to calculate accurate and consistent severity scores for their systems' vulnerabilities. Scoring vulnerabilities in this way helps prioritize resources and determine how to respond to a given threat. Scores are calculated using metrics such as the type of attack vector (network, adjacent, local, physical), the attack complexity, privileges required, whether or not the attack requires user interaction, and the impact of successful exploitation on an organization's confidentiality, integrity, and availability of data. Scores can range from 0 to 10, depending on these metrics.

Threat plus Vulnerability equals Risk: A threat is a new incident with potential harm. A vulnerability is a known weakness. Risk is the potential damage when a threat exploits a vulnerability.

For example, SQL injection is considered a vulnerability since an attacker could leverage queries to extract data from an organization's database. This attack would have a higher CVSS score rating if it could be performed without authentication over the internet than if an attacker needed authenticated access to the internal network and separate authentication to the target application. These types of things must be considered for all vulnerabilities we encounter.

Threat

A Threat is a process that amplifies the potential of an adverse event, such as a threat actor exploiting a vulnerability. Some vulnerabilities raise more threat concerns over others due to the probability of the vulnerability being exploited. For example, the higher the reward of the outcome and ease of exploitation, the more likely the issue would be exploited by threat actors.

Exploit

An Exploit is any code or resources that can be used to take advantage of an asset's weakness. Many exploits are available through open-source platforms such as Exploit-db or the Rapid7 Vulnerability and Exploit Database. We will often see exploit code hosted on sites such as GitHub and GitLab as well.

Risk

Risk is the possibility of assets or data being harmed or destroyed by threat actors.

Risk is the effect of uncertainty on objectives, ISO 31000. An effect can be positive (opportunity) or negative (threat). No objectives, no risk.

To differentiate the three, we can think of it as follows:

Risk: something bad that could happen

Threat: something bad that is happening

Vulnerabilities: weaknesses that could lead to a threat

Vulnerabilities, Threats, and Exploits all play a part in measuring the level of risk in weaknesses by determining the likelihood and impact. For example, vulnerabilities that have reliable exploit code and are likely to be used to gain access to an organization's network would significantly raise the risk of an issue due to the impact. If an attacker had access to the internal network, they could potentially view, edit, or delete sensitive documents crucial for business operations. We can use a qualitative risk matrix to measure risk based on likelihood and impact with the table shown below.

Likelihood Impact Matrix: High likelihood with low impact is medium risk (3), medium impact is high risk (4), high impact is highest risk (5). Medium likelihood with low impact is low risk (2), medium impact is medium risk (3), high impact is high risk (4). Low likelihood with low impact is lowest risk (1), medium impact is low risk (2), high impact is medium risk (3).

In this example, we can see that a vulnerability with a low likelihood of occurring and low impact would be the lowest risk level, while a vulnerability with a high likelihood of being exploited and the highest impact on an organization would represent the highest risk and would want to be prioritized for remediation.

Asset Management

When an organization of any kind, in any industry, and of any size needs to plan their cybersecurity strategy, they should start by creating an inventory of their data assets. If you want to protect something, you must first know what you are protecting! Once assets have been inventoried, then you can start the process of asset management. This is a key concept in defensive security.

Asset Inventory

Asset inventory is a critical component of vulnerability management. An organization needs to understand what assets are in its network to provide the proper protection and set up appropriate defenses. The asset inventory should include information technology, operational technology, physical, software, mobile, and development assets. Organizations can utilize asset management tools to keep track of assets. The assets should have data classifications to ensure adequate security and access controls.

Application and System Inventory

An organization should create a thorough and complete inventory of data assets for proper asset management for defensive security. Data assets include:

All data stored on-premises. HDDs and SSDs in endpoints (PCs and mobile devices), HDDs & SSDs in servers, external drives in the local network, optical media (DVDs, Blu-ray discs, CDs), flash media (USB sticks, SD cards). Legacy technology may include floppy disks, ZIP drives (a relic from the 1990s), and tape drives.

All of the data storage that their cloud provider possesses. Amazon Web Services (AWS), Google Cloud Platform (GCP), and Microsoft Azure are some of the most popular cloud providers, but there are many more. Sometimes corporate networks are "multi-cloud," meaning they have more than one cloud provider. A company's cloud provider will provide tools that can be used to inventory all of the data stored by that particular cloud provider.

All data stored within various Software-as-a-Service (SaaS) applications. This data is also "in the cloud" but might not all be within the scope of a corporate cloud provider account. These are often consumer services or the "business" version of those services. Think of online services such as Google Drive, Dropbox, Microsoft Teams, Apple iCloud, Adobe Creative Suite, Microsoft Office 365, Google Docs, and the list goes on.

All of the applications a company needs to use to conduct their usual operation and business. Including applications that are deployed locally and applications that are deployed through the cloud or are otherwise Software-as-a-Service.

All of a company's on-premises computer networking devices. These include but aren't limited to routers, firewalls, hubs, switches, dedicated intrusion detection and prevention systems (IDS/IPS), data loss prevention (DLP) systems, and so on.

All of these assets are very important. A threat actor or any other sort of risk to any of these assets can do significant damage to a company's information security and ability to operate day by day. An organization needs to take its time to assess everything and be careful not to miss a single data asset, or they won't be able to protect it.

Organizations frequently add or remove computers, data storage, cloud server capacity, or other data assets. Whenever data assets are added or removed, this must be thoroughly noted in the data asset inventory.